

#31 · 團隊管理

[未來] 技術代號 A-P2-5 / D-P2-2 / U-P2-2 / O-P2-3 · 約 10 週

一句話：個人版升級成 Workspace 版

為什麼要修

每個帳號獨立，看不到別人的東西。

現在怎樣

drizzle/schema.ts 已有 teams + teamMemberships 表 (visibility: private / team_shared 欄位也有)。但無 team-aware repository、無 RLS middleware、無 SSO。

問題在哪

工作室同事無法共享 LoRA / 資產、老闆看不到員工用了多少額度、B2B 客戶不能採購。

要改什麼

三件事：(1) team-aware RLS middleware、(2) 共享資產 UI (共享 LoRA / 資產庫)、(3) SAML / OIDC SSO (Okta / Azure AD / Google Workspace)。

涉及檔案

server/middleware/rls.ts (新增)

server/repositories/ (全部加 RLSContext 參數)

client/src/pages/TeamsPage.tsx (新增)

server/services/auth/saml.ts + oidc.ts (新增)

Claude Code 提示詞 (複製貼上)

把下面這段話完整複製，貼到 Claude Code (或 /claude 對話)。Claude Code 會依此完成此項修復。完成後跑下方驗證步驟確認。

請依照計畫附錄 C.13 實作 A-P2-5 / D-P2-2 / U-P2-2 / O-P2-3 多用戶 + RLS + SSO :

季度級工程，10 週。建議拆三個 sub-sprint。

【Sub-sprint 1 : RLS middleware (4 週)】

1. 新增 server/middleware/rls.ts :

```
````typescript
export interface RLSContext { userId: number; teamId: number | null; role: "owner"|"admin"|"member" }

export async function withRLS<T>(ctx: RLSContext, query: (db: Db, scope: RLSContext) =>
Promise<T>): Promise<T> {
 return query(db, ctx);
}

// helper : 套到所有 SELECT
export function teamAwareWhere(table: any, ctx: RLSContext): SQL {
 return or(
 and(eq(table.ownership, "private"), eq(table.ownerId, ctx.userId)),
 and(eq(table.ownership, "team_shared"), ctx.teamId ? eq(table.teamId, ctx.teamId) : sql`false`),
);
}
````
```

2. 修改所有 repository 接收 RLSContext，每個 find / list 預設套 teamAwareWhere(table, ctx)。

3. 改 tRPC context middleware 自動填入 RLSContext (從 JWT 解 userId、查 teams 表取 teamId)。

【Sub-sprint 2 : 共享 UI (3 週)】

4. 新增 client/src/pages/TeamsPage.tsx :

- 建團隊 / 邀請成員 / 角色管理 (owner/admin/member)
- 切換「個人 / 團隊 X」viewport (影響所有資產列表)
- 額度監控：每個成員今月用了多少 points

5. 新增 client/src/pages/SharedAssetsPage.tsx : 在 ImageStudio / VideoStudio 加「來自團隊」tab，能用團隊成員訓練的 LoRA / 角色 / 配方。

6. 修改 fineTunedModels / digitalAssetLibrary 加 ownership 欄位 (private / team_shared / public showcase) 。

【Sub-sprint 3 : SSO (3 週)】

7. 新增 server/services/auth/saml.ts : 用 passport-saml , 支援 Okta / Azure AD / Google Workspace。

8. 新增 server/services/auth/oidc.ts : 用 passport-openidconnect , 支援 Google / GitHub OIDC。

9. Just-in-time 建用戶 : SSO 登入成功後 , 若用戶不存在自動建帳號 + 加入預設 team。

10. 新增 client/src/pages/EnterpriseSettings.tsx : admin 可設定 SAML metadata / OIDC client。

不要做的事 : 不要做「跨團隊資產分享」(複雜權限)。不要把所有歷史一次性遷成 team-aware (保留 ownership = private 為預設)。不要做企業計費自動 invoice (手動處理)。

如何驗證做完了

建一個團隊 T1 → 邀請使用者 U2 → U1 訓練一個 LoRA 標為 team_shared → U2 在 ImageStudio 能用此 LoRA。SAML 配 Okta → 員工用 Okta SSO 登入自動加入 T1。Admin 看到 T1 今月用了 5000 points。

預估耗時

10 週